

CYBERSECURITY & ETHICAL HACKING

INTERNSHIP PROGRAM

ApexPlanet Software Pvt. Ltd.

TASK 2: NETWORK SECURITY & SCANNING

Nmap Scan Report + Vulnerability Analysis

Timeline: Days 13 - 24

Report Type	Network Security Scan Report — Task 2 Submission
Intern Name	Diwakar Chandra
Offer Letter ID	APSPL2632803
Organization	ApexPlanet Software Pvt. Ltd.
Task Duration	Days 13–24
Date	10 May 2026

1. Executive Summary

This report documents the completion of Task 2 of the ApexPlanet Cybersecurity & Ethical Hacking Internship Program. Over Days 13 through 24, advanced network security concepts were studied and applied, including passive and active reconnaissance, port scanning, vulnerability scanning, packet analysis with Wireshark, and firewall configuration using iptables. The target machine used for all scanning exercises was Metasploitable2 (IP: 192.168.56.102) running in an isolated virtual lab environment. All activities were performed legally and ethically within the controlled lab setup.

2. Task Objective

Learn and demonstrate reconnaissance techniques, network scanning methods, vulnerability assessment, packet analysis, and basic firewall configuration in a controlled ethical hacking lab environment.

3. Reconnaissance

3.1 Passive Reconnaissance

Passive reconnaissance involves gathering information about a target without directly interacting with it, leaving no traces in target logs.

- Whois Lookup: Used to gather domain registration details, owner information, registrar, and name servers. Command: `whois target.com`
- Nslookup: DNS query tool to find IP addresses, mail servers, and name servers for a domain. Command: `nslookup target.com`
- Google Dorking: Used advanced Google search operators to find sensitive information indexed by search engines. Examples: `site:target.com filetype:pdf`, `intitle:index.of`, `inurl:admin`
- Shodan: Search engine for internet-connected devices. Used to find open ports, running services, and vulnerabilities on public-facing systems without sending any packets to the target.

3.2 Active Reconnaissance

Active reconnaissance involves directly interacting with the target system to gather information.

- Ping Sweep: Identified live hosts on the network using: `nmap -sn 192.168.56.0/24`. Result: Discovered 2 live hosts — 192.168.56.101 (Kali) and 192.168.56.102 (Metasploitable2).
- Banner Grabbing: Retrieved service banners to identify software versions. Used Netcat: `nc 192.168.56.102 21`. Result: 220 (vsFTPd 2.3.4) — identified a critically vulnerable version.

4. Port & Service Scanning

Nmap (Network Mapper) was used to perform comprehensive port and service scanning against Metasploitable2 (192.168.56.102).

4.1 TCP SYN Stealth Scan

```
# TCP SYN Stealth Scan (-ss)
nmap -ss 192.168.56.102

# Results:
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
5432/tcp  open  postgresql
8180/tcp  open  unknown
```

4.2 Service Version Detection

```
# Service Version Detection (-sV)
nmap -sV 192.168.56.102

# Results:
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian
23/tcp    open  telnet   Linux telnetd
80/tcp    open  http     Apache httpd 2.2.8
3306/tcp  open  mysql    MySQL 5.0.51a
5432/tcp  open  postgresql PostgreSQL 8.3.0
```

4.3 OS Detection

```
# OS Detection (-O)
nmap -O 192.168.56.102

# Result:
OS: Linux 2.6.X
Network Distance: 1 hop
```

4.4 Full Aggressive Scan

```
# Full Aggressive Scan (-A)
nmap -A 192.168.56.102
# Combines OS detection + version detection + script scanning + traceroute
```

Scan Results Summary:

Port	Service	Version	Risk Level
------	---------	---------	------------

21/tcp	FTP	vsftpd 2.3.4	Critical
22/tcp	SSH	OpenSSH 4.7p1	Medium
23/tcp	Telnet	Linux telnetd	High
25/tcp	SMTP	Postfix smtpd	Medium
80/tcp	HTTP	Apache 2.2.8	High
3306/tcp	MySQL	5.0.51a	High
5432/tcp	PostgreSQL	8.3.0	Medium
8180/tcp	HTTP-Alt	Apache Tomcat	High

5. Vulnerability Scanning

OpenVAS (Open Vulnerability Assessment System) / Nessus Essentials was configured and used to perform a comprehensive vulnerability scan against Metasploitable2.

5.1 Setup

- Installed and configured OpenVAS on Kali Linux
- Created a new scan target: 192.168.56.102 (Metasploitable2)
- Ran a Full and Fast scan profile
- Scan duration: approximately 45 minutes

5.2 Vulnerability Findings

Severity	Vulnerability	Port	Description
Critical	vsftpd 2.3.4 Backdoor	21/tcp	Remote command execution via backdoor shell
Critical	UnrealIRCd Backdoor	6667/tcp	Contains backdoor allowing RCE
High	Samba MS-RPC Shell Command Injection	445/tcp	Allows arbitrary command execution
High	PHP CGI Argument Injection	80/tcp	Remote code execution via PHP CGI
High	Apache Tomcat Default Credentials	8180/tcp	Admin panel accessible with default password
High	MySQL No Root Password	3306/tcp	Root account has no password set
Medium	Telnet Unencrypted	23/tcp	All data including credentials sent in

			plaintext
Medium	OpenSSH Outdated Version	22/tcp	Multiple known CVEs in version 4.7p1
Low	SMTP Open Relay	25/tcp	May allow spam relaying
Low	PHP Information Disclosure	80/tcp	phpinfo() page exposed

6. Packet Analysis with Wireshark

6.1 HTTP Traffic Capture

- Started Wireshark capture on eth0 (Host-Only interface)
- Applied display filter: http
- Browsed to DVWA running on Metasploitable2: <http://192.168.56.102/dvwa>
- Finding: Full HTTP requests visible including cookies, session tokens, and form data — all unencrypted
- Mitigation: Always use HTTPS to encrypt web traffic

6.2 FTP Credential Extraction

```
# Wireshark filter to capture FTP traffic
ftp

# What was captured:
USER: msfadmin
PASS: msfadmin

# Credentials transmitted in PLAINTEXT!
# Mitigation: Use SFTP or FTPS instead of FTP
```

6.3 DNS Traffic Analysis

- Applied filter: dns
- Captured DNS queries and responses for domains resolved by lab machines
- Finding: DNS queries are unencrypted by default — DNS spoofing is possible
- Mitigation: Use DNS over HTTPS (DoH) or DNS over TLS (DoT)

6.4 SYN Flood Simulation

```
# Simulate SYN flood using hping3
hping3 -S --flood -V -p 80 192.168.56.102

# Wireshark filter to observe:
tcp.flags.syn == 1

# Observation: Massive SYN packets with no corresponding ACK
# This simulates a DDoS SYN flood attack
# Mitigation: SYN cookies, rate limiting, firewall rules
```

7. Firewall Basics with iptables

Basic firewall rules were created using iptables on Kali Linux to demonstrate traffic filtering and port scan blocking.

7.1 Basic iptables Rules

```
# View existing rules
iptables -L -v -n

# Block all incoming traffic by default
iptables -P INPUT DROP

# Allow established connections
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Allow SSH (port 22)
iptables -A INPUT -p tcp --dport 22 -j ACCEPT

# Allow HTTP (port 80)
iptables -A INPUT -p tcp --dport 80 -j ACCEPT

# Block Telnet (port 23) - insecure protocol
iptables -A INPUT -p tcp --dport 23 -j DROP

# Block FTP (port 21) - replace with SFTP
iptables -A INPUT -p tcp --dport 21 -j DROP

# Block port scan attempts (SYN flood protection)
iptables -A INPUT -p tcp --syn -m limit --limit 1/s -j ACCEPT
iptables -A INPUT -p tcp --syn -j DROP

# Save rules
iptables-save > /etc/iptables/rules.v4
```

7.2 Demonstrating Port Scan Blocking

- Before iptables rule: nmap -sS 192.168.56.101 showed all ports open
- After applying DROP rules: nmap showed ports as filtered
- Result: Successfully blocked unauthorized port scan attempts

8. Key Findings & Risk Assessment

Finding	Risk	Recommendation
vsftpd 2.3.4 Backdoor on port 21	Critical	Upgrade to latest vsftpd immediately
Telnet enabled (port 23)	High	Disable Telnet, use SSH instead

MySQL root with no password	High	Set strong root password, restrict remote access
FTP transmits credentials in plaintext	High	Replace FTP with SFTP
Apache Tomcat default credentials	High	Change default admin credentials
Outdated OpenSSH version	Medium	Update to latest OpenSSH
DNS traffic unencrypted	Medium	Implement DoH or DoT
HTTP without HTTPS	Medium	Install SSL certificate, redirect to HTTPS

9. Key Learnings

- Passive reconnaissance leaves no traces — Shodan and Google Dorking can reveal surprising information about targets without alerting them.
- Nmap is extremely powerful — combining -sV, -O, and -A flags reveals a complete picture of a target's attack surface.
- Legacy protocols like FTP and Telnet are fundamentally insecure — real-world systems should never use them.
- vsftpd 2.3.4 contains a backdoor — a classic example of supply chain attacks where malicious code is injected into software.
- Wireshark makes it clear why encryption matters — unencrypted credentials are trivially captured on shared networks.
- Firewalls are the first line of defense — proper iptables rules significantly reduce the attack surface.

10. Deliverables Summary

Deliverable	Description	Status
Nmap Scan Report	Full port/service/OS scan of Metasploitable2	Completed
Vulnerability Report	OpenVAS scan findings with severity ratings	Completed
Wireshark Analysis	FTP credential capture + SYN flood analysis	Completed
iptables Demo	Firewall rules blocking ports and scan attempts	Completed
GitHub Repository	All notes, scan outputs, and analysis	Completed

5-min Demo Video	Screen recording of scan and findings	Completed
------------------	---------------------------------------	-----------

This report was prepared as part of the ApexPlanet Cybersecurity & Ethical Hacking Internship Program.

All activities were performed in an isolated lab environment for educational purposes only.

www.apexplanet.in | info@apexplanet.in | +91 9905879870